

"Salla Store" E-commerce Project

Case Study:

Project Name: Salla Store

Sector: E-commerce (selling innovative electronic products and smart devices online).

Objective: To provide a secure and reliable e-commerce platform that ensures the protection of customer data, the integrity of transactions, and business continuity.

Key Security Challenges:

- Protecting personal and financial customer data (credit cards).
 - Ensuring transaction integrity and preventing fraud.
 - Providing continuous and available service (preventing DDoS attacks).
 - Protecting intellectual property of products and supplier contracts.
 - Complying with data protection regulations (such as GDPR or local equivalents).
-

Applying ISO/IEC 27001 Requirements to "Salla Store"

We will review the previously discussed requirements and controls and how "Salla Store" will implement them, specifying the required evidence.

First: Framework - Context, Interested Parties, and Scope Requirements

1.1. Requirement (4.1): Understanding the Organization and Its Context

- **Description of Application in "Salla Store":**
 - Salla Store management will conduct regular (annual or semi-annual) workshops to assess internal and external factors affecting information security.
 - **Internal Factors:** May include a lack of trained information security staff, outdated infrastructure, multiple departments with different access privileges, employee information security culture.
 - **External Factors:** May include intense competition in the e-commerce market, increasing cyber attack threats, changes in data protection laws, fluctuating customer trust, and relationships with external payment gateways and suppliers.
 - SWOT and PESTLE analyses will be used to identify information security-related risks and opportunities. For example, infrastructure weakness (weakness) may lead to data leakage risks, while increased information security awareness (opportunity) can be leveraged to improve customer trust.

- **Process:** Conduct SWOT and PESTLE analysis during management review meetings (e.g., twice a year).
- **Required Evidence:**
 - **SWOT/PESTLE Analysis Reports:** Written documents containing a detailed analysis of internal and external factors and their impact on information security.
 - **Management Review Meeting Minutes:** Signed minutes documenting analysis discussions, decisions made, and resource allocation for addressing risks and opportunities.
 - **Risk and Opportunity Registers:** A dynamic document recording identified security risks, their assessment, treatment plans, and identified opportunities to enhance security.

1.2. Requirement (4.2): Understanding the Needs and Expectations of Interested Parties

- **Description of Application in "Salla Store":**
 - Salla Store will identify key interested parties: customers (most important party), employees, suppliers (for products and services like hosting and payment gateways), regulatory bodies (e.g., ministries of commerce and communications), investors, partners.
 - Information security requirements will be collected from each party. For example, customers expect protection of their financial and personal data, suppliers expect secure communication, and regulatory bodies require compliance with specific laws.
- **Process:** Identify stakeholders and their needs through surveys (for customers), interviews (with management and suppliers), and meetings (with internal teams).
- **Required Evidence:**
 - **Stakeholder Maps:** Documents identifying interested parties, their relationship with the organization, and their main interests.
 - **Documented Requirements:** A detailed list of information security requirements for each interested party, and how they will be met through the ISMS.
 - **Communication Records:** Meeting minutes, emails, or survey reports documenting communication with stakeholders regarding security requirements.

1.3. Requirement (4.3): Determining the Scope of the Information Security Management System (ISMS)

- **Description of Application in "Salla Store":**

- The ISMS scope for Salla Store will include:
 - **Systems:** E-commerce platform (website and applications), Customer Relationship Management (CRM) system, inventory and procurement management systems, online payment systems, database servers, backup systems.
 - **Locations:** Data center (if internal) or utilized cloud hosting services, management and employee offices.
 - **People:** All permanent and contracted employees, suppliers with access to sensitive data.
 - **Data:** Personal and financial customer data, product data, supplier data, operational data.
- Interfaces and dependencies will be clearly defined, such as reliance on external payment gateways (e.g., Stripe or PayPal), shipping companies, and cloud hosting providers.
- **Process:** Define the boundaries of the ISMS, considering dependencies and interfaces.
- **Required Evidence:**
 - **ISMS Scope Document:** A formal document clearly defining the ISMS boundaries, covered assets (information, systems, people), locations, and processes.
 - **System Architecture Diagrams:** Drawings illustrating the different components of Salla Store's infrastructure and the dependencies between them and external systems.
 - **Service Level Agreements (SLAs) and Data Processing Agreements (DPAs) with Third Parties:** Contracts with suppliers and service providers outlining their security responsibilities.

Second: Organizational Controls

2.1. Control (5.1): Policies for Information Security

- **Description of Application in "Salla Store":**
 - Salla Store will develop comprehensive information security policies covering areas such as: acceptable use of resources policy, password management policy, backup policy, incident response policy, personal data protection policy.
 - These policies will comply with consumer protection laws and electronic transaction laws in the country where Salla Store operates.
- **Process:** Develop overarching and task-specific policies aligning with legal, regulatory, and organizational needs.
- **Required Evidence:**

- **Approved Policy Documents:** PDF files or internal documents bearing the approval of senior management (e.g., signed by the CEO or Head of Information Security).
- **Communication Records:** Emails, notifications on the employee management system, or training records proving that policies have been communicated to all employees.
- **Policy Review Logs:** A schedule showing the review dates for each policy, reviewers, and any modifications made.

2.2. Control (5.2): Information Security Roles and Responsibilities

- **Description of Application in "Salla Store":**
 - Salla Store will designate an "Information Security Officer" (CISO or Information Security Manager).
 - Information security responsibilities will be defined for each department:
 - **Development Team:** Responsible for writing secure code and conducting penetration tests.
 - **Operations Team:** Responsible for securing servers and networks and managing backups.
 - **Customer Service Team:** Responsible for secure handling of customer data and reporting any suspected security incidents.
 - **Senior Management:** Responsible for providing resources and support for the ISMS.
- **Process:** Clearly define roles, assign responsibilities, and ensure personnel understand their obligations.
- **Required Evidence:**
 - **Role Descriptions:** Documents defining specific security tasks and responsibilities for each job role.
 - **Organizational Charts:** Diagrams showing the management hierarchy and security responsibilities within Salla Store's organizational structure.
 - **Acknowledgement Forms:** Documents signed by employees acknowledging that they have read and understood information security policies and their responsibilities.
 - **Training Records:** Records of employee attendance at security awareness training sessions and their responsibilities.

2.3. Control (5.3): Segregation of Duties

- **Description of Application in "Salla Store":**

- To mitigate risks, critical duties will be separated. For example:
 - The person responsible for developing code will not be the same person responsible for deploying code to the production environment.
 - The person responsible for processing customer orders will not have direct access to credit card databases (handled by the payment gateway).
 - The person responsible for user management and granting permissions will not have full administrative access to all systems.
- If complete segregation is not possible (e.g., in a small team), compensating controls will be applied, such as the Four-eyes principle or detailed audit logs.
- **Process:** Identify potential conflicts in duties and establish segregation with compensating controls if necessary.
- **Required Evidence:**
 - **Segregation of Duties Policy:** A document outlining the guiding principles for segregation of duties within Salla Store.
 - **Access Control Logs:** Systemic records showing who has access to which system or data, and who performed specific actions.
 - **Audit Reports:** Internal or external reports verifying the implementation of the segregation of duties policy and identifying any violations or loopholes.
 - **Roles and Permissions Matrix:** A table clearly outlining the different roles within the organization and the permissions granted to each role.

2.4. Control (5.4): Management Responsibilities

- **Description of Application in "Salla Store":**
 - Senior management at Salla Store will be committed to supporting information security. This includes:
 - Allocating necessary budget and resources (for training, purchasing security tools, hiring specialists).
 - Participating in periodic information security reviews.
 - Addressing escalated security issues.
 - Fostering a security awareness culture among employees.
- **Process:** Assign and communicate responsibilities, monitor compliance, and provide necessary resources.
- **Required Evidence:**

- **Management Meeting Minutes:** Minutes documenting senior management discussions about information security, budget and resource-related decisions, and ISMS performance reviews.
- **Resource Allocation Records:** Documents proving the allocation of financial and human resources for information security activities (e.g., invoices for security software purchases, employment contracts for security experts).
- **ISMS Performance Reports:** Periodic reports presented to senior management summarizing the security posture, incidents, compliance, and control effectiveness.
- **Security Policy Statement Document:** A statement issued by senior management affirming their commitment to information security and its importance to the organization.

Absolutely, here's the translation of the preceding case study details for "ISalla Store" into English, focusing on the data protection controls:

Third: Data Protection Controls

3.1. Control (8.10): Information Deletion

- **Control:** "Are secure methods implemented to delete information when no longer required?"
 - **Description of Application at "ISalla Store":**
 - Since "ISalla Store" handles large volumes of customer data (e.g., order details, payment data, shipping information), it is essential to establish clear policies and procedures for the secure deletion of data when its purpose for retention ends or after the expiration of the legal retention period (e.g., very old transaction data, information of permanently closed customer accounts).
 - This includes deleting data from databases, backup systems, server logs, and any other storage media.
 - Secure deletion tools and techniques will be used to ensure that deleted data cannot be recovered.
 - **Process:** "Use tools and methods for secure deletion of sensitive data from storage devices."
 - For example, data overwriting will be used for hard drives, records will be deleted from databases using secure deletion commands, and physical media (like old hard drives) will be destroyed at the end of their lifecycle.
- **Required Evidence:**

- **Deletion Policies:** A formal document specifying when and how different types of data are to be deleted, who is responsible for the process, and the approved methods for secure deletion.
- **Logs of Deletion Activities:** Detailed records documenting the dates of deletion operations, the type of data deleted, the method used, and who performed the deletion.
- **Verification Records:** Reports or test results demonstrating that data has been securely deleted and cannot be recovered. This may include reports from verification tools or review minutes.

3.2. Control (8.11): Data Masking

- **Control:** "Is data masking used to protect sensitive information in non-production environments?"
 - **Description of Application at "ISalla Store":**
 - Development and testing (non-production) environments often require data similar to real data for effective testing. However, these environments should not contain actual, sensitive customer data.
 - "ISalla Store" will implement data masking or data anonymization techniques in development and testing environments. This means replacing sensitive data (such as credit card numbers, customer names, email addresses) with fictitious or altered data that appears real but does not reveal the original identity.
 - **Process:** "Implement masking techniques to obfuscate sensitive data where applicable."
 - Specialized data masking tools will be used, or scripts will be developed to automate the data masking process before transferring data to development/testing environments.
- **Required Evidence:**
 - **Data Masking Policies:** A document outlining when, why, and how data masking is to be applied, the types of data that must be masked, and the environments that require it.
 - **Implementation Reports:** Documents detailing how data masking techniques were applied, the tools used, and the data that was masked.
 - **Testing Logs:** Records of test results verifying that data has been correctly masked in non-production environments and does not reveal sensitive information.

3.3. Control (8.12): Data Leakage Prevention (DLP)

- **Control:** "Are measures in place to prevent unauthorized exfiltration of data?"
 - **Description of Application at "ISalla Store":**
 - The leakage of customer data or intellectual property is one of the biggest risks facing "ISalla Store". To prevent this, Data Leakage Prevention (DLP) solutions will be implemented.
 - DLP tools will monitor data leaving "ISalla Store"'s network or being accessed by employees. They can detect sensitive data (such as credit card numbers, national ID numbers, customer email addresses) and prevent it from leaving via unauthorized channels (e.g., email, USB, unauthorized cloud storage).
 - **Process:** "Deploy data loss prevention (DLP) tools and monitor for suspicious activities."
 - DLP tools will be installed on endpoints (employee computers) and at "ISalla Store"'s network gateways to monitor data flow.
- **Required Evidence:**
 - **DLP Tool Configurations:** Screenshots or detailed documentation of the settings and configurations of the DLP tools used, including specific rules and parameters for detecting and preventing sensitive data exfiltration.
 - **Incident Reports:** Documents recording any data leakage attempts detected by the DLP system, including event details, data involved, action taken, and subsequent investigation.
 - **Monitoring Logs:** Regular logs from DLP tools showing data movement, suspicious activities observed, and any alerts or blocks executed. These logs are crucial for review and auditing.

Overall Conclusion of the "ISalla Store" Case Study:

This integrated study demonstrates how "ISalla Store" can apply ISO/IEC 27001 requirements to protect its information assets. By:

1. **Understanding the Context, Identifying Interested Parties, and Defining the Scope:** The project ensures a clear understanding of its security environment and requirements.
2. **Implementing Organizational Controls:** Such as clear policies, defined roles and responsibilities, segregation of duties, and management support, to establish a solid foundation for information security.
3. **Implementing Data Protection Controls:** Such as secure information deletion, data masking in non-production environments, and data leakage prevention, to ensure the protection of sensitive information throughout its lifecycle.

The presence of the evidence mentioned for each control and requirement is crucial not only for compliance with ISO/IEC 27001 but also for building a strong security culture within "ISalla Store" and maintaining customer trust in the competitive e-commerce market.

Okay, I will translate the entire detailed case study for "ISalla Store" from Arabic to English, including the introduction, the context/framework section, the organizational controls section, and the new data protection controls section, along with the specified evidence.

Case Study: "ISalla Store" E-commerce Project (Continuation)

Project Name: ISalla Store

Sector: E-commerce (selling innovative electronic products and smart devices online).

Additional Security Objectives:

- Ensuring secure deletion of information when no longer needed.
- Protecting sensitive data in non-production environments.
- Preventing unauthorized data leakage.

Applying ISO/IEC 27001 Requirements to "ISalla Store" (Continuation of Security Controls)

We will review the new controls from the checklist and how "ISalla Store" will apply them, along with the required evidence.

Third: Data Protection Controls

3.1. Control (8.10): Information Deletion

- **Control (CONTROL):** "Are secure methods in place for deleting information when it is no longer required?"
 - **Description of Application in "ISalla Store":**
 - Since "ISalla Store" handles large volumes of customer data (e.g., order details, payment data, shipping information), it is essential to establish clear policies and procedures for securely deleting data when its retention purpose ends or after the legal retention period expires (e.g., very old transaction data, information of customers who have permanently closed their accounts).
 - This includes deleting data from databases, backup systems, server logs, and any other storage media.
 - Secure deletion tools and techniques will be used to ensure that deleted data cannot be recovered.
 - **Process:** "Utilize tools and methods for secure deletion of sensitive data from storage media."

- For example, data overwriting will be used for hard drives, records will be deleted from databases using secure deletion commands, and physical media (like old hard drives) will be destroyed at the end of their lifecycle.
- **Required Evidence:**
 - **Deletion Policies:** A formal document outlining when and how different types of data are to be deleted, who is responsible, and the approved methods for secure deletion.
 - **Logs of Deletion Activities:** Detailed records documenting deletion operation dates, type of data deleted, method used, and who performed the deletion.
 - **Verification Records:** Reports or test results confirming that data has been securely deleted and cannot be recovered. This can include reports from verification tools or review minutes.

3.2. Control (8.11): Data Masking

- **Control (CONTROL):** "Is data masking used to protect sensitive information in non-production environments?"
 - **Description of Application in "ISalla Store":**
 - Development and testing environments (non-production) often require data similar to real data for effective testing. However, these environments should not contain actual sensitive customer data.
 - "ISalla Store" will implement data masking or data anonymization techniques in development and testing environments. This means replacing sensitive data (e.g., credit card numbers, customer names, email addresses) with fictitious or altered data that appears realistic but does not reveal original identities.
 - **Process:** "Apply masking techniques to obscure sensitive data where applicable."
 - Specialized data masking tools will be used, or scripts will be developed to automate the data masking process before transferring it to development/testing environments.
- **Required Evidence:**
 - **Data Masking Policies:** A document defining when, why, and how data masking is applied, the types of data to be masked, and the environments that require it.
 - **Implementation Reports:** Documents detailing how data masking techniques were applied, the tools used, and the data that was masked.

- **Testing Logs:** Records of test results verifying that data has been correctly masked in non-production environments and does not reveal sensitive information.

3.3. Control (8.12): Data Leakage Prevention (DLP)

- **Control (CONTROL):** "Are measures in place to prevent unauthorized data leakage?"
 - **Description of Application in "ISalla Store":**
 - Data leakage of customer information or intellectual property is one of the biggest risks facing "ISalla Store." To prevent this, Data Leakage Prevention (DLP) solutions will be implemented.
 - DLP tools will monitor data leaving ISalla Store's network or being accessed by employees. They can detect sensitive data (e.g., credit card numbers, identification numbers, customer email addresses) and prevent it from leaving through unauthorized channels (e.g., email, USB, unauthorized cloud storage).
 - **Process:** "Deploy Data Leakage Prevention (DLP) tools and monitor for suspicious activities."
 - DLP tools will be installed on endpoints (employee computers) and network gateways of "ISalla Store" to monitor data flow.
- **Required Evidence:**
 - **DLP Tool Configurations:** Screenshots or detailed documentation of the settings and configurations of the DLP tools used, including specific rules and parameters for detecting and preventing sensitive data leakage.
 - **Incident Reports:** Documents recording any data leakage attempts detected by the DLP system, including event details, involved data, action taken, and subsequent investigation.
 - **Monitoring Logs:** Regular logs from DLP tools showing data movement, suspicious activities detected, and any alerts or blocks implemented. These logs are vital for review and auditing.

Conclusion:

ISO/IEC 27001 requirements to protect its information assets. By:

1. **Understanding the Context, Identifying Interested Parties, and Defining Scope:** The project ensures a clear understanding of its security environment and requirements.
2. **Implementing Organizational Controls:** Such as clear policies, defined roles and responsibilities, segregation of duties, and management support, to establish a solid foundation for information security.

3. **Implementing Data Protection Controls:** Such as secure information deletion, data masking in non-production environments, and data leakage prevention, to ensure the protection of sensitive information throughout its lifecycle.

The existence of the mentioned evidence for each control and requirement is crucial not only for ISO/IEC 27001 compliance but also for building a strong security culture within "ISalla Store" and maintaining customer trust in the competitive e-commerce market.

Systematically applying these requirements and controls will help "Salla Store" build a robust information security management system, thereby increasing customer trust, protecting critical project assets, and ensuring compliance with legal and regulatory requirements in the evolving e-commerce landscape. The evidence mentioned above is crucial for demonstrating compliance with standards during any internal or external audit.